

Impilo vNext v1.2 — Technical Companion Spec **(Claude Opus Implementation Standard)**

Scope: Ring 0 Kernel (TSHEPO, VITO, VARAPI, TUSO, INDAWO, MSIKA, ZIBO, BUTANO, MUSHEX) + Eventing + Safety/Consistency + Platform + Federation + Coverage/Claims/Settlement + AI Governance

Version: 1.2.0-canonical

Status: Architecture frozen. Implementation must conform.

Global Conventions (Applies to ALL Ring 0)

A. Base URL & Versioning

All services expose two API surfaces:

1. Internal (Impilo-native apps, ring-to-ring calls, privileged ops)
2. External (third-party apps, partner EMRs, pod federation)

Paths:

- /internal/v1/...
- /external/v1/...

No breaking changes in /v1. Breaking changes require /v2 and a deprecation window.

B. Required Tenant / Pod Context Headers

All business APIs MUST require these headers:

- X-Tenant-ID: <uuid|string> — logical tenant/customer (public facility group, private group, etc.)

- X-Pod-ID: <string> — identifies the deployment pod (national for Spine)
- X-Request-ID: <uuid> — request trace id (generated if missing)
- X-Correlation-ID: <uuid> — propagated across calls/events
- Authorization: Bearer <JWT> — issued by TSHEPO (internal/external differ by audience)

Hard rule: any business request lacking required tenant or pod context MUST fail with structured error.

Enumerated exceptions may exist only for:

1. health/readiness probes
2. infrastructure control endpoints explicitly marked as internal platform-only
3. bootstrap and federation handshake endpoints where tenant context is not yet resolvable at request start
4. explicitly approved public metadata endpoints that produce no tenant-affecting business action

All exceptions must be documented in the service contract and reviewed as part of architecture governance.

C. Error Response Standard (all services)

All errors must be JSON:

```
{
  "error": {
    "code": "STRING_ENUM",
    "message": "Human readable message",
    "details": { "any": "object" },
    "request_id": "uuid",
    "correlation_id": "uuid"
  }
}
```

D. Idempotency

Any create/update command endpoint MUST accept:

- Idempotency-Key: <uuid|string>

If repeated with same body → return same result. If same key different body → 409 IDENTITY_CONFLICT.

E. Timeouts

Internal callers must set:

- X-Client-Timeout-MS: <int>

Services must honor and fail fast when exceeded.

F. Operational Domain Contracts

This technical companion applies not only to Kernel entities and clinical objects, but also to canonical operational objects including inspections, complaints, public-health events, investigations, enforcement actions, campaigns, incidents, coverage objects, claims objects, settlement objects, and AI-linked workflow objects once introduced into vNext.

These objects must follow the same standards for identifiers, auditability, idempotency, event contracts, tenant/pod context, schema governance, and lifecycle compatibility.

G. Shared Capability Reuse Rule

No jurisdiction-specific public-health or local-authority feature may introduce a new standalone service if the requirement can be satisfied through shared domain objects, configuration, role scoping, workflow variation, rules, forms/templates, or dashboard composition. Any exception requires an explicit architecture decision record demonstrating why reuse is insufficient.

H. Financial Integrity Rule

Any operation affecting money movement, reserve, guarantee, reimbursement, member liability, provider liability, remittance, or settlement finality must be idempotent, auditable, evented, and governed by defined reversal/compensation and reconciliation paths.

I. AI Integrity Rule

Any AI-assisted workflow-linked output must record model/version, inference timestamp, confidence or score where relevant, and human acceptance or override where relevant. It must remain reversible or ignorable at the decision layer unless explicitly approved for governed automation.

1) Ring 0 Service Contracts (The Interface)

1.1 TSHEPO — Trust & Policy Service (IAM + Consent + Entitlements)

1.1.1 Token issuance (External)

POST /external/v1/oauth/token

Headers: X-Tenant-ID, X-Pod-ID, X-Request-ID, X-Correlation-ID

Body (password grant example; other grants allowed):

```
{
  "grant_type": "password",
  "client_id": "string",
  "username": "string",
  "password": "string",
  "scope": "openid profile impilo.api",
  "audience": "impilo-kernel"
}
```

200 Response:

```
{
  "access_token": "jwt",
```

```
"token_type": "Bearer",  
"expires_in": 900,  
"scope": "openid profile impilo.api",  
"refresh_token": "optional"  
}
```

Errors:

- 401 AUTH_INVALID_CREDENTIALS
- 403 AUTH_CLIENT_NOT_ALLOWED
- 429 RATE_LIMITED

1.1.2 Policy Decision (PDP) — Sync authorization checks (Class A / F1 where relevant)

POST /internal/v1/pdp/decide

Used by Gateway/OPA or privileged internal services.

Body:

```
{  
  "subject": {  
    "user_id": "prid-or-sub",  
    "roles": ["CLINICIAN"],  
    "facility_id": "frid",  
    "assurance_level": "aal2"  
  },  
  "action": "clinical.prescribe.controlled_substance",  
  "resource": {  
    "patient_cpid": "cpid",  
    "encounter_id": "string",  
    "medication_code": "MSIKA:SKU:123"  
  },  
  "context": {  
    "tenant_id": "X-Tenant-ID",  
    "pod_id": "X-Pod-ID",  
    "purpose_of_use": "TREATMENT"  
  }  
}
```

```
}  
}
```

200 Response:

```
{  
  "decision": "ALLOW",  
  "policy_version": "2026-02-08.1",  
  "reason_codes": ["CONSENT_OK", "PRIVILEGE_OK"],  
  "obligations": [  
    { "type": "AUDIT", "level": "MANDATORY" }  
  ],  
  "ttl_seconds": 30  
}
```

Decision values:

- ALLOW
- DENY
- BREAK_GLASS_REQUIRED
- STEP_UP_REQUIRED

Errors:

- 403 POLICY_DENY
- 409 STALE_CONTEXT
- 412 STEP_UP_REQUIRED
- 503 PDP_UNAVAILABLE

1.1.3 Offline Entitlement Issuance (Edge devices)

POST /internal/v1/offline/entitlements

Body:

```
{  
  "device_id": "string",  
  "subject_id": "prid-or-sub",
```

```
"scope": [  
  "clinical.capture.vitals",  
  "clinical.capture.notes"  
],  
"valid_from": "2026-02-08T00:00:00Z",  
"valid_to": "2026-02-08T06:00:00Z",  
"constraints": {  
  "facility_id": "frid",  
  "patient_cpid_allowlist": ["cpid1","cpid2"]  
}  
}
```

201 Response:

```
{  
  "entitlement_jwt": "jwt",  
  "entitlement_id": "uuid",  
  "policy_version": "2026-02-08.1"  
}
```

Errors:

- 403 ENTITLEMENT_NOT_ALLOWED
- 409 DEVICE_NOT_TRUSTED

1.2 VITO — Client Registry (MPI + CRID/CPID mapping)

1.2.1 Create/Upsert Patient (Internal)

PUT /internal/v1/patients/{crid}

Headers: tenant context + Idempotency-Key

Body:

```
{  
  "crid": "CRID-123",  
  "demographics": {
```

```

    "given_name": "string",
    "family_name": "string",
    "dob": "YYYY-MM-DD",
    "sex": "M|F|X|U"
  },
  "identifiers": [
    { "system": "NATID", "value": "string" },
    { "system": "PASSPORT", "value": "string" }
  ],
  "contacts": [{ "type": "PHONE", "value": "+263..." }],
  "addresses": [{ "line1": "string", "district": "string" }]
}

```

200 Response:

```

{
  "crid": "CRID-123",
  "cpid": "CPID-abc",
  "status": "ACTIVE",
  "dedupe_score": 0.92,
  "version": 7,
  "links": {
    "fhir_patient_ref": "Patient/CPID-abc"
  }
}

```

1.2.2 Query Patient (External, read-only by default)

GET /external/v1/patients?identifier=NATID:12345&dob=YYYY-MM-DD

Returns a minimal, policy-filtered response.

200 Response:

```

{
  "matches": [
    { "cpid": "CPID-abc", "confidence": 0.91 }
  ]
}

```



```
}
```

1.2.3 Merge Patients (National-authoritative only)

POST /internal/v1/patients/merge

Body:

```
{
  "survivor_crid": "CRID-1",
  "merged_crids": ["CRID-2", "CRID-3"],
  "reason": "DUPLICATE_REGISTRATION"
}
```

200 Response:

```
{
  "merge_id": "uuid",
  "survivor_crid": "CRID-1",
  "alias_map": [
    { "from": "CRID-2", "to": "CRID-1" }
  ],
  "version": 8
}
```

Errors:

- 403 FEDERATION_NOT_AUTHORIZED
- 409 MERGE_CONFLICT
- 422 INVALID_MERGE_REQUEST

1.2.4 Required Events Emitted by VITO

- impilo.vito.patient.created.v1
- impilo.vito.patient.updated.v1
- impilo.vito.patient.merged.v1

1.2A VARAPI — Provider Registry

Purpose:

Canonical provider identity, licensure, privilege truth, and contractable provider anchor.

Required Events:

- impilo.varapi.provider.created.v1
- impilo.varapi.provider.updated.v1
- impilo.varapi.provider.privilege.revoked.v1

1.2B TUSO — Facility Registry

Purpose:

Canonical registry for health service-delivery facilities.

Responsibilities:

- facility topology
- departments
- capabilities
- service availability
- federation-aware facility identity

Boundary rule:

TUSO governs clinical and service-delivery facilities. Non-clinical regulated premises and public-health operational sites must not be forced into the facility model where semantics do not fit.

Required Events:

- impilo.tuso.facility.created.v1
- impilo.tuso.facility.updated.v1
- impilo.tuso.facility.capability.updated.v1
- impilo.tuso.snapshot.facilities.v1

1.2C INDAWO — Site & Premises Registry

Purpose:

Canonical registry for regulated premises and public-health operational sites including markets, schools, water points, waste sites, ports of entry, food premises, abattoirs, vending zones, public toilets, cemeteries, and similar non-clinical locations.

Responsibilities:

- canonical site/premises identifiers
- geospatial and jurisdictional linkage
- operator/owner references where relevant
- lifecycle status
- inspection, compliance, surveillance, complaints, and emergency-response linkage hooks

1.2C.1 Create/Upsert Site or Premises (Internal)

PUT /internal/v1/sites/{site_id}

1.2C.2 Query Site or Premises (External, policy-filtered)

GET /external/v1/sites/{site_id}

Required Events:

- impilo.indawo.site.created.v1
- impilo.indawo.site.updated.v1
- impilo.indawo.site.status.changed.v1
- impilo.indawo.snapshot.sites.v1

1.3 MSIKA — Product, Service, Tariff & Benefit Catalog Registry (Orderables/Billables/Tariffs/Benefits)

1.3.1 Create Product (Internal)

POST /internal/v1/products

Body:

```
{
  "product_id": "SKU-123",
  "name": "Amoxicillin 500mg",
  "category_id": "CAT-ANTIBIOTICS",
  "codes": [{ "system": "ATC", "value": "J01CA04" }],
  "is_orderable": true,
  "is_billable": true,
  "effective_from": "2026-02-01",
  "effective_to": null
}
```

201 Response:

- returns product + version

1.3.2 Update Tariff (Class A / F1 when settlement-impacting)

PUT /internal/v1/tariffs/{tariff_id}

Requirement: MUST trigger TSHEPO PDP check and audit log.

Body:

```
{
  "tariff_id": "TAR-001",
  "product_id": "SKU-123",
  "currency": "ZWL",
  "amount": 1200.00,
  "effective_from": "2026-03-01"
}
```

Errors:

- 403 POLICY_DENY
- 409 EFFECTIVE_DATE_CONFLICT
- 422 INVALID_TARIFF

1.3.3 External Read (Partners)

GET /external/v1/products?category_id=CAT-ANTIBIOTICS&as_of=2026-02-08

Returns policy-filtered, stable fields.

1.3.4 Required Events Emitted by MSIKA

- impilo.msika.product.created.v1
- impilo.msika.product.updated.v1
- impilo.msika.tariff.updated.v1
- impilo.msika.benefit.catalog.updated.v1
- impilo.msika.snapshot.products.v1

1.4 BUTANO — Shared Health Record (FHIR Longitudinal Truth)

1.4.1 FHIR Profile Strategy (Canonical Truth)

BUTANO is the canonical longitudinal memory. Canonical resources:

- Patient
- Encounter
- Observation
- Condition
- MedicationRequest
- MedicationDispense
- AllergyIntolerance
- Procedure
- Immunization
- DiagnosticReport

Not canonical in Butano:

- UI workflow state
- queue management state
- temporary drafts
- claims adjudication state
- settlement state

1.4.2 FHIR Endpoints

- Internal: /internal/v1/fhir/*
- External: /external/v1/fhir/*

1.4.3 Identity Rules in FHIR

Patient.id = CPID-...

PII fields restricted; if present, must be governed by policy & tenant.

1.4.4 Butano Events

- impilo.butano.fhir.resource.created.v1
- impilo.butano.fhir.resource.updated.v1

1.4.5 Canonical Truth Rule

If a data element must survive local application replacement and remain longitudinally valid beyond the lifecycle of a departmental workflow application, it belongs either in BUTANO or in the appropriate Ring 0 canonical registry.

Local execution stores may hold transient workflow state, task state, draft state, and operational convenience data, but they must not become hidden system-of-record replacements for national truth domains.

1.5 MUSHEX — Finance Engine / Claims Switch / Settlement Rail

Purpose:

- payment routing

- claims switching
- remittance
- settlement orchestration
- authorization and reservation hooks
- reconciliation
- reversal and refund orchestration
- payout integration

1.5.1 Create Financial Authorization or Reservation

POST /internal/v1/financial/authorizations

1.5.2 Submit Settlement Instruction

POST /internal/v1/settlements

1.5.3 Reconcile Settlement

POST /internal/v1/reconciliation/settlements/{settlement_id}

Required Events:

- impilo.mushex.authorization.created.v1
- impilo.mushex.authorization.updated.v1
- impilo.mushex.settlement.initiated.v1
- impilo.mushex.settlement.completed.v1
- impilo.mushex.settlement.failed.v1
- impilo.mushex.settlement.reversed.v1
- impilo.mushex.reconciliation.completed.v1

2) Coverage, Medical Insurance, and Payer Domain Contracts

2.1 Coverage and Eligibility Service

Purpose:

- membership
- beneficiary coverage

- eligibility
- plan/package assignment
- waiting periods
- exclusions
- benefit balances
- financial clearance inputs

2.1.1 Create or Update Membership

PUT /internal/v1/coverage/memberships/{membership_id}

2.1.2 Eligibility Check

POST /internal/v1/coverage/eligibility/check

Required Events:

- impilo.coverage.membership.created.v1
- impilo.coverage.membership.updated.v1
- impilo.coverage.eligibility.checked.v1
- impilo.coverage.coverage.changed.v1

2.2 Scheme, Plan and Benefit Administration

Purpose:

- scheme setup
- plan/package definition
- deductibles, co-pays, ceilings, sub-limits
- chronic and disease program rules
- provider-network rules
- formulary and package rules

2.2.1 Create Plan

POST /internal/v1/coverage/plans

2.2.2 Update Benefit Rule

PUT /internal/v1/coverage/benefit-rules/{rule_id}

Required Events:

- impilo.coverage.plan.created.v1
- impilo.coverage.plan.updated.v1
- impilo.coverage.benefit.rule.updated.v1

2.3 Provider Contracting and Network Management

Purpose:

- contracted provider networks
- rate schedules
- reimbursement modes
- validity periods
- provider sanctions and suspension impacts

2.3.1 Create Provider Contract

POST /internal/v1/provider-contracts

2.3.2 Suspend Contract

POST /internal/v1/provider-contracts/{contract_id}/suspend

Required Events:

- impilo.contracts.provider.created.v1
- impilo.contracts.provider.updated.v1
- impilo.contracts.provider.suspended.v1

2.4 Preauthorization and Utilization Management

Purpose:

- preauth

- utilization review
- admissions approval
- chronic medication approval
- exception handling

2.4.1 Submit Preauthorization

POST /internal/v1/preauth

Required Events:

- impilo.preauth.requested.v1
- impilo.preauth.updated.v1
- impilo.preauth.approved.v1
- impilo.preauth.denied.v1

2.5 Claims Capture and Adjudication

Purpose:

- electronic claims
- automated and manual adjudication
- duplicate detection
- coding edits
- rule evaluation
- pend, approve, deny, appeal

2.5.1 Submit Claim

POST /internal/v1/claims

2.5.2 Adjudicate Claim

POST /internal/v1/claims/{claim_id}/adjudicate

2.5.3 Appeal Claim Decision

POST /internal/v1/claims/{claim_id}/appeals

Required Events:

- impilo.claims.submitted.v1
- impilo.claims.validated.v1
- impilo.claims.adjudicated.v1
- impilo.claims.approved.v1
- impilo.claims.denied.v1
- impilo.claims.appealed.v1

2.6 Contributions, Billing and Collections

Purpose:

- premiums
- employer billing
- receipts
- arrears
- subsidy/co-financing linkage

2.6.1 Create Contribution Schedule

POST /internal/v1/contributions/schedules

2.6.2 Record Receipt

POST /internal/v1/contributions/receipts

Required Events:

- impilo.contributions.scheduled.v1
- impilo.contributions.received.v1
- impilo.contributions.arrears.updated.v1

2.7 Provider Payments, Remittance and Settlement

Purpose:

- payment batches
- remittance advice
- capitation or fee-for-service payout
- recovery and clawback
- settlement exceptions

2.7.1 Create Provider Payment Batch

POST /internal/v1/provider-payments/batches

2.7.2 Release Payment Batch

POST /internal/v1/provider-payments/batches/{batch_id}/release

2.7.3 Reverse or Recover

POST /internal/v1/provider-payments/recoveries

Required Events:

- impilo.payments.batch.created.v1
- impilo.payments.batch.released.v1
- impilo.payments.remittance.generated.v1
- impilo.payments.recovery.initiated.v1

3) The Eventing Standard (Law 3 & 4)

3.1 Topic Naming Convention

Format:

- impilo.{service}.{domain}.{entity}.{action}.v{N}

Examples:

- impilo.vito.patient.created.v1
- impilo.vito.patient.merged.v1
- impilo.msika.catalog.product.updated.v1

- impilo.msika.snapshot.products.v1
- impilo.butano.fhir.observation.created.v1
- impilo.tshepo.policy.decision.logged.v1
- impilo.coverage.eligibility.checked.v1
- impilo.claims.adjudicated.v1
- impilo.mushex.settlement.completed.v1
- impilo.ai.inference.recorded.v1

3.2 Mandatory Event Envelope Fields

All events MUST carry this envelope (top-level):

- event_id (uuid)
- event_type (string)
- schema_version (int)
- correlation_id (uuid)
- causation_id (uuid|null)
- idempotency_key (string)
- producer (service name)
- tenant_id
- pod_id
- occurred_at (RFC3339)
- emitted_at (RFC3339)
- subject_type (e.g., patient, product)
- subject_id (entity id)
- payload (delta or snapshot)
- meta (optional debug + policy version)

Financial and settlement events must additionally carry:

- financial_reference_type
- financial_reference_id
- amount
- currency
- settlement_state where relevant

AI-linked workflow events must additionally carry:

- model_id
- model_version
- inference_class
- human_review_required

3.3 JSON Schema Template — Delta Event

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "ImpiloDeltaEvent",
  "type": "object",
  "required": [
    "event_id", "event_type", "schema_version",
    "correlation_id", "idempotency_key",
    "producer", "tenant_id", "pod_id",
    "occurred_at", "emitted_at",
    "subject_type", "subject_id",
    "payload"
  ],
  "properties": {
    "event_id": { "type": "string", "format": "uuid" },
    "event_type": { "type": "string" },
    "schema_version": { "type": "integer", "minimum": 1 },
    "correlation_id": { "type": "string", "format": "uuid" },
    "causation_id": { "type": ["string", "null"], "format": "uuid" },
    "idempotency_key": { "type": "string" },
    "producer": { "type": "string" },
    "tenant_id": { "type": "string" },
    "pod_id": { "type": "string" },
    "occurred_at": { "type": "string", "format": "date-time" },
    "emitted_at": { "type": "string", "format": "date-time" },
    "subject_type": { "type": "string" },
    "subject_id": { "type": "string" },
    "payload": {
      "type": "object",
      "required": ["op", "after", "before", "changed_fields"],
      "properties": {
```

```

      "op": { "type": "string", "enum":
["CREATE","UPDATE","DELETE","MERGE","REVOKE"] },
      "before": { "type": ["object","null"] },
      "after": { "type": ["object","null"] },
      "changed_fields": { "type": "array", "items": { "type": "string" } }
    }
  },
  "meta": { "type": "object" }
}

```

3.4 JSON Schema Template — Snapshot Event

```

{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "ImpiloSnapshotEvent",
  "type": "object",
  "required": [
    "event_id","event_type","schema_version",
    "correlation_id","producer","tenant_id","pod_id",
    "occurred_at","emitted_at",
    "subject_type","subject_id",
    "payload"
  ],
  "properties": {
    "payload": {
      "type": "object",
      "required": ["snapshot_type","as_of","items","page"],
      "properties": {
        "snapshot_type": { "type": "string", "enum": ["FULL","PARTIAL"] },
        "as_of": { "type": "string", "format": "date-time" },
        "items": { "type": "array", "items": { "type": "object" } },
        "page": {
          "type": "object",
          "required": ["cursor","has_more"],
          "properties": {
            "cursor": { "type": ["string","null"] },
            "has_more": { "type": "boolean" }
          }
        }
      }
    }
  }
}

```

```
}  
}  
}  
}  
}  
}
```

3.5 Topic Partitioning Decision Record (Mandatory per Topic)

For every event topic, the owning team must define and maintain a partitioning decision record containing:

1. topic name
2. partition key
3. ordering guarantee required
4. expected producer volume
5. expected consumer patterns
6. rebalancing and hot-partition risk
7. reason for chosen key
8. replay/bootstrap implications
9. migration strategy if repartitioning becomes necessary

No default partitioning choice shall be treated as immutable architecture law without such a decision record.

3.6 Partition Key Rules (Crucial)

General rule: partition by the identifier that minimizes cross-partition joins and preserves entity ordering.

- VITO (patient): subject_id = cpid (or crid until CPID assigned; after assignment always CPID)
- BUTANO clinical events: patient_cpid
- MSIKA product events: category_id (primary)
- TSHEPO decisions/audit: subject_id (user_id/prid) OR patient_cpid for patient-scoped actions
- TUSO facility events: frid
- INDAWO site/premises events: site_id

- Coverage events: membership_id or eligibility_id by lifecycle
- Claims events: claim_id
- Settlement events: settlement_id or payment_batch_id

Hard requirement: event producers MUST include partition_key in event meta.partition_key for deterministic routing.

4) Consistency, Safety, Financial Execution & AI Governance

4.1 Code Pattern: Class A (Sync Truth Required)

Pattern: request must be authorized via TSHEPO PDP before commit.

Gateway enforces OPA → OPA calls TSHEPO /pdp/decide → allow/deny

Service also writes a decision audit event (or TSHEPO emits it) with policy_version.

4.2 Code Pattern: Class B (Bounded Stale Allowed)

Pattern: operate on local projection if freshness within threshold; otherwise require sync or block.

Services maintain projection timestamp watermark:
projection_freshness_ms

4.3 Code Pattern: Class C (Offline Allowed with Entitlement)

- Verify Offline-Entitlement token (signed by Tshepo)
- Record action locally
- Emit offline.action.recorded event when connectivity returns
- Reconcile conflicts using domain rules; unresolved conflicts go to queue for review

4.4 Financial Execution Classes

- F1 — Immediate hard truth required
- F2 — Near-real-time checked

- F3 — Deferred or batch

4.5 Real-Time Financial Clearance

An eligibility or authorization call may return:

- approved
- partial
- pending
- denied
- reserved
- guarantee_of_payment_issued

F1 operations MUST record:

1. decision basis
2. liability split
3. reservation or guarantee references where issued
4. expiry/TTL where relevant

4.6 Settlement State Machine

Minimum states:

1. INITIATED
2. ELIGIBILITY_VERIFIED
3. PREAUTHORIZED
4. RESERVED
5. PROVISIONALLY_ADJUDICATED
6. APPROVED
7. REMITTED
8. PAID
9. SETTLED
10. REVERSED
11. RECONCILED
12. DISPUTED
13. RECOVERED

4.7 Reversal and Compensation

Every irreversible financial operation must define whether true reversal is possible, whether compensation is required instead, reconciliation behavior, and event emission on reversal or compensation.

4.8 AI Capability Classes

- I1 — Insight only
- I2 — Recommendation with human action
- I3 — Governed low-risk automation

4.9 Workflow Use Rule

Any AI output used in care, public-health, claims, or financial workflow must be linked to workflow reference, decision record, actor context, model metadata, and acceptance or override outcome.

4.10 Model Governance Rule

Every production AI model must define owner, approval status, approved use cases, prohibited use cases, drift threshold, rollback strategy, and human oversight requirements.

Required AI Events:

- impilo.ai.model.approved.v1
- impilo.ai.model.withdrawn.v1
- impilo.ai.inference.recorded.v1
- impilo.ai.alert.generated.v1
- impilo.ai.override.recorded.v1
- impilo.ai.drift.detected.v1

5.0 AI Service Surfaces

Approved AI-related technical services may include:

- inference gateway

- summarization service
- risk scoring service
- anomaly detection service
- coding assist service
- forecasting service
- model registry control plane

5.0.1 Inference Record Contract

POST /internal/v1/ai/inference-records

Body:

```
{
  "model_id": "string",
  "model_version": "string",
  "inference_class": "I1|I2|I3",
  "workflow_ref": "string",
  "subject_type": "PATIENT|CLAIM|SITE|OUTBREAK|PROVIDER|BATCH",
  "subject_id": "string",
  "output_summary": "string",
  "score": 0.87,
  "confidence": 0.82,
  "human_review_required": true
}
```

Response:

```
{
  "inference_record_id": "uuid",
  "status": "RECORDED"
}
```

5) Infrastructure Blueprint (Platform)

5.1 Reference Stack for Ring 0

- Compute: Kubernetes (namespaces per ring; strict network policies)

- Gateway: Envoy Gateway (or Istio IngressGateway)
- Service Mesh: Istio (Envoy sidecars)
- Policy: OPA (or OPA Gatekeeper + external OPA for request authZ)

5.1.1 OPA Enforcement Pattern (Copy-paste high level)

Ingress → Envoy ext_authz filter → OPA (or OPA calls TSHEPO PDP)

OPA decision cached short TTL for Class B actions; Class A/F1 must be real-time or $TTL \leq 30s$

Mandatory headers injected by gateway after allow:

- X-Policy-Decision: ALLOW
- X-Policy-Version: <string>
- X-Decision-Reason: <codes>

5.2 Schema Registry

Pick one:

1. Apicurio Registry (self-hosted, Kafka-friendly)
2. AWS Glue Schema Registry (if AWS-native)

Rules:

1. All schemas versioned
2. CI blocks incompatible changes by default

5.3 Audit Ledger

Options:

1. Append-only Postgres ledger with:
 - immutable table (no updates/deletes)
 - hash chaining per record (prev_hash, record_hash)
2. AWS QLDB (managed immutability) if AWS

Mandatory audit events:

- PDP decision logs
- break-glass usage
- consent changes
- privilege changes
- patient merges
- tariff updates
- cross-pod federation actions
- eligibility decisions
- preauthorization decisions
- claim adjudication
- settlement initiation/completion/reversal
- provider payment release
- AI inference use in workflow
- AI override and model withdrawal

5.4 Security (Vault/HSM Integration)

HashiCorp Vault for secrets + dynamic DB creds

KMS/HSM integration points:

1. signing keys for entitlements
2. CPID pseudonymization keys (HSM-backed)
3. rotation schedule + re-key strategy documented

5.5 Observability (Golden Signals for Kernel)

Monitor per service:

- Latency: p50/p95/p99 by endpoint and decision class
- Traffic: RPS, event publish rate
- Errors: 4xx/5xx, PDP denies, auth failures, schema violations
- Saturation: CPU/mem, DB connections, queue lag, consumer lag

Mandatory additional kernel metrics:

- Projection lag (ms) per consumer group
- Snapshot generation duration + failures
- Policy decision cache hit rate
- Audit write success rate
- Settlement completion/failure rates
- Reconciliation lag
- AI inference success/failure and drift alerts

6) Federation Protocol (Technical)

6.0 Jurisdiction Configuration Packs (Technical Enforcement)

Jurisdiction packs are configuration bundles that adapt shared Impilo vNext capabilities to a specific operational context without creating code forks.

A jurisdiction pack may include:

- enabled modules
- role maps
- workflow routes
- checklist libraries
- form definitions
- geography bindings
- dashboard layouts
- document templates
- SLA and escalation settings
- legal reference metadata

Technical rules:

1. packs are versioned artifacts
2. packs must be testable in CI
3. packs must declare compatibility with platform version and schema set
4. pack changes must be auditable
5. packs must not redefine canonical identifiers or break event contracts

6.1 Pod Registration Handshake (Private Pod → National Spine)

6.1.1 Register Pod

POST TSHEPO (National) /external/v1/federation/pods/register

Headers: X-Tenant-ID, X-Pod-ID=<privatepod>, Authorization (pod admin)

Body:

```
{
  "pod_id": "privatepod-001",
  "org_name": "Private Hospital Group",
  "public_keys": {
    "signing_key": "PEM",
    "mtls_cert": "PEM"
  },
  "requested_authorities": {
    "identity": "NATIONAL_CONSUMER",
    "terminology": "NATIONAL_CONSUMER",
    "facility": "POD_AUTHORITATIVE_WITH_LINKAGE",
    "site_premises": "POD_AUTHORITATIVE_WITH_LINKAGE",
    "provider": "NATIONAL_CONSUMER",
    "catalog": "NATIONAL_CONSUMER"
  },
  "reporting_obligations": ["SURVEILLANCE_MINSET_V1"]
}
```

201 Response:

```
{
  "pod_id": "privatepod-001",
  "status": "PENDING_APPROVAL",
  "federation_id": "uuid",
  "next_steps": ["UPLOAD_ATTESTATION", "AWAIT_APPROVAL"]
}
```

6.1.2 Approve Pod (National admin)

POST /internal/v1/federation/pods/{pod_id}/approve

Emits:

- impilo.tshepo.federation.pod.approved.v1

6.2 Federation Auth Model

All pod-to-spine calls require:

1. mTLS
2. JWT with aud=federation
3. X-Pod-ID verified against cert CN/SAN

6.3 Conflict Resolution Logic (Explicit)

Case: Private Pod tries to update National-authoritative identity field

Example: pod attempts PUT /external/v1/patients/{crid} with a restricted identifier system (NATID) flagged as National-authoritative.

Response:

- HTTP 403 Forbidden
- error.code = "FEDERATION_AUTHORITY_VIOLATION"
- details includes domain + field + authority rule

```
{
  "error": {
    "code": "FEDERATION_AUTHORITY_VIOLATION",
    "message": "Pod is not authorized to update NATIONAL-authoritative
identity fields.",
    "details": {
      "domain": "vito.identity",
      "field": "identifiers[NATID]",
      "authority": "NATIONAL_SPINE_ONLY"
    },
    "request_id": "uuid",
    "correlation_id": "uuid"
  }
}
```

```
}  
}
```

Event logic:

- VITO emits no update event
- TSHEPO emits an audit event:
 - `impilo.tshepo.federation.authority_violation.logged.v1`

Case: Pod sends update to pod-authoritative domain with linkage

Allowed but must include linkage metadata:

- `meta.linkage.national_ref = <id>`

If missing → 422 INVALID_LINKAGE

6.4 Settlement Participation Rule

If a pod originates claims or provider payments but does not hold settlement authority, it must hand off settlement orchestration to the national MusheX rail through defined contracts and events.

6.5 AI Participation Rule

Pods may not deploy workflow-affecting AI outputs into nationally governed flows without approved model governance and compatibility declaration.

7) Minimum Production Gates

The platform is not production-ready until the following are true:

1. Clinical classes enforced
2. Financial classes enforced
3. Real-time eligibility and reservation tested
4. Claim adjudication tested
5. Settlement initiation/completion/reversal tested

6. Reconciliation tested
7. Audit ledger complete
8. Federation protocol proven
9. Contract tests and schema compatibility gates active
10. Observability active for clinical, financial, and AI signals
11. At least one AI-assisted workflow proven with audit and override
12. At least one end-to-end care-to-claim-to-settlement flow proven

8) Final Technical Position

Impilo vNext is not merely an EHR platform with integrations. It is a governed national operating environment for care, public health, coverage and entitlement, claims and settlement, shared truth and federation, and AI-assisted but human-governed insight and action.

Implementation must preserve:

1. canonical shared truth
2. operational safety
3. financial integrity
4. reversibility and reconciliation
5. auditability
6. explainability where AI is involved
7. disciplined reuse across jurisdictions and schemes